

Ingegneria Sociale e Intelligenza Artificiale: Progettazione e Analisi di uno Scenario Simulato

Esercitazione didattica — scenario ipotetico: Azienda Delta S.p.A.

1. Sintesi

Il presente documento costruisce ed analizza uno scenario simulato e interamente ipotetico di attacco di ingegneria sociale potenziato dall'Intelligenza Artificiale (AI), a scopo didattico. Lo scenario coinvolge un'azienda fittizia ("Delta S.p.A.") e non fa riferimento ad alcuna persona, organizzazione o evento reale. A differenza di un caso storico documentato, qui l'attacco viene descritto per componenti strutturali — pretesto, canale, leva psicologica, escalation — e non come testo finale pronto all'uso, poiché l'obiettivo dell'esercitazione è comprendere il funzionamento dei vettori di attacco, non produrne uno riutilizzabile.

2. Scenario Ipotetico

Organizzazione bersaglio	Delta S.p.A. (azienda manifatturiera fittizia, 500 dipendenti, sede principale in Italia con una filiale estera)
Target primario	Dipendente dell'ufficio amministrazione/finanza con potere di autorizzare bonifici
Obiettivo dell'attaccante	Ottenere un trasferimento di fondi non autorizzato (scenario di tipo Business Email Compromise)
Superficie di esposizione sfruttata	Contenuti pubblici dei dirigenti (interviste, webinar, profili LinkedIn, video di eventi aziendali)

3. Struttura dell'Attacco per Componenti

Di seguito la struttura schematica delle fasi ipotizzate, utile per comprendere l'architettura dell'attacco senza produrre un testo direttamente riutilizzabile.

3.1 Fase di ricognizione (OSINT)

- Raccolta di informazioni pubbliche sull'organigramma aziendale e sui rapporti gerarchici
- Identificazione di eventi plausibili da usare come pretesto (es. acquisizione, fusione, revisione contabile)
- Raccolta di materiale audio/video pubblico del dirigente da impersonare, per un eventuale utilizzo in una fase successiva di sintesi vocale o video

3.2 Fase di aggancio — schema dell'email di innesco

Anziché fornire il testo integrale del messaggio, la tabella seguente ne descrive la funzione di ciascun componente, così da poterne riconoscere la struttura in un messaggio reale.

Mittente apparente	Dirigente di alto livello (es. CFO), con dominio email visivamente simile a quello legittimo (typosquatting)
Oggetto	Riferimento a un evento plausibile e riservato (es. "operazione confidenziale"), formulato per generare curiosità e urgenza
Leva psicologica primaria	Autorità gerarchica + riservatezza + urgenza temporale
Richiesta esplicita	Disponibilità a gestire una comunicazione riservata al di fuori delle normali procedure, senza dettagli operativi immediati
Assenza di red flag evidenti	Nessun link né allegato nel primo contatto, per non attivare i filtri email automatici

3.3 Fase di escalation — ruolo ipotizzato del deepfake

Nello scenario, qualora il target mostrasse esitazione, l'attacco potrebbe prevedere un secondo canale di conferma sincrono (videochiamata o messaggio vocale), con l'obiettivo di rafforzare la percezione di autenticità sfruttando contenuti audio/video sintetici. A livello di meccanismo:

- Impiego di modelli di sintesi vocale addestrati su registrazioni pubbliche per riprodurre timbro e cadenza del dirigente impersonato
- Eventuale impiego di deepfake video in tempo reale durante una videoconferenza, per aggirare la verifica visiva
- Coinvolgimento di più "presenze" familiari nella stessa chiamata, per generare un effetto di riprova sociale

3.4 Fase di monetizzazione

Nello scenario, la richiesta finale (es. trasferimento di fondi o condivisione di credenziali) verrebbe introdotta solo dopo che la fiducia del target è stata consolidata attraverso le fasi precedenti, riducendo la probabilità che venga sottoposta a verifica indipendente.

4. Analisi dei Vettori Coinvolti

4.1 Spear phishing potenziato dall'AI

L'uso di modelli linguistici generativi elimina gli errori grammaticali tipici del phishing tradizionale e consente di adattare automaticamente tono e registro al contesto organizzativo specifico, rendendo più difficile il riconoscimento tramite le euristiche linguistiche classiche.

4.2 Deepfake audio e video

La disponibilità di materiale pubblico (interviste, conferenze, contenuti social) rende tecnicamente possibile addestrare modelli di sintesi vocale e video anche per organizzazioni di dimensioni medio-piccole, non solo per grandi multinazionali.

4.3 Leve psicologiche

- **Autorità:** l'impersonificazione di un dirigente riduce la propensione del target a mettere in discussione la richiesta.
- **Urgenza e riservatezza:** limitano il tempo disponibile per una verifica indipendente.
- **Riprova sociale:** la presenza di più voci o volti familiari in un secondo canale rafforza la percezione di legittimità.

5. Framework di Rilevamento IA-Based

5.1 Indicatori testuali

- Richieste che aggirano le normali procedure di autorizzazione interna
- Combinazione di urgenza e richiesta di riservatezza
- Discrepanze nell'header del messaggio (dominio del mittente, percorso di instradamento)

5.2 Indicatori audio/video

- Prosodia o intonazione non coerenti con il contenuto emotivo del messaggio
- Artefatti visivi ai bordi del volto, specialmente durante il movimento o il cambio di angolazione
- Assenza di rumore ambientale coerente con il contesto dichiarato della chiamata
- Latenza anomala nei turni di conversazione durante interazioni sincrone

6. Strategie di Difesa

- Verifica multicanale obbligatoria per qualsiasi richiesta finanziaria o di accesso a dati sensibili, tramite un canale indipendente e pre-verificato
- Approvazioni multiple indipendenti per operazioni finanziarie rilevanti, così da evitare che un singolo dipendente possa autorizzare da solo un trasferimento critico
- Formazione periodica del personale su scenari simulati che includano non solo phishing testuale ma anche deepfake audio/video
- Adozione di strumenti di rilevamento automatico dei contenuti sintetici nelle comunicazioni aziendali critiche

7. Conclusioni

Lo scenario simulato mostra come, anche in assenza di un precedente storico specifico, la combinazione di ricognizione OSINT, spear phishing e deepfake rappresenti un vettore di attacco plausibile per qualsiasi organizzazione che esponga pubblicamente contenuti audio o video dei propri dirigenti. La difesa efficace non può basarsi unicamente sulla capacità del singolo dipendente di riconoscere un contenuto sintetico, ma richiede procedure organizzative strutturate di verifica indipendente, affiancate da strumenti tecnologici di rilevamento.